Non-Human Identity & Service Account Review

Asterbridge Care Technologies | Project 05 | 15 October 2026 | Lab assessment

Summary

I reviewed three named Active Directory service identities and used a deliberately created orphaned-account scenario to test detection and remediation. The active legacy reporting account was flagged in the inventory, then disabled and removed from two unnecessary backup groups. The final export records the account as disabled with only its default Domain Users membership.

Measure	Result
Named identities reviewed	3
Initially active identities	2
Potential orphan flags	1 (controlled lab scenario)
Orphan accounts remediated	1
Dependency checks	No matching Windows services or tasks on two machines

Accounts in scope

Account	Initial observation	Recorded outcome
OktaService	Enabled; password never expires; Domain Users; description blank	Left unchanged. Document ownership and credential controls before altering the hybrid integration.
svc-clinic-backup	Disabled; member of backup Read and Write groups	NTFS ACLs configured. Scheduled-task effectiveness not verified.
svc-legacy-reports	Enabled; owner unassigned; retired reporting application; backup Read and Write groups	Disabled and both backup memberships removed.

Main finding: NHI-F01

The simulated legacy reporting account remained enabled after its fictional application retirement and had backup access that its former purpose did not justify. In a real environment, an unused identity with valid credentials could expose the resources available to its groups. Medium was used as a training-only risk rating, not a formal business risk decision.

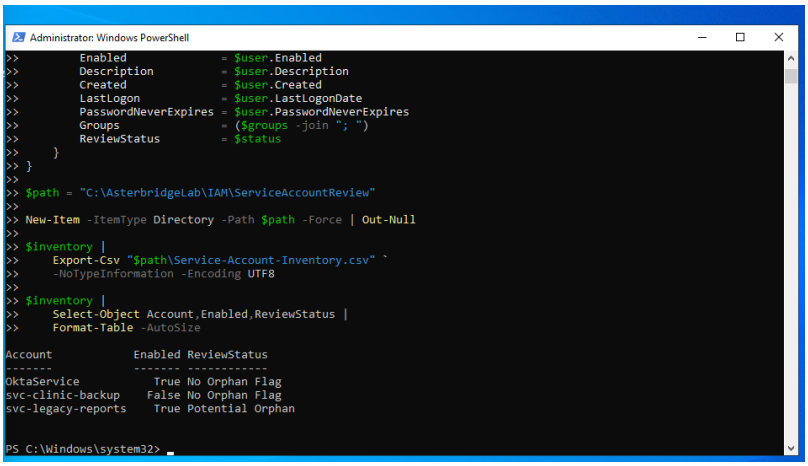
Decision: Decommission the lab identity

The assumed application retirement and lack of owner were supplied by the test scenario. On DC01 and WS01, targeted searches found no Windows services or scheduled tasks running as this identity. After that limited check, the account was disabled and both backup group memberships were removed. The disabled object was retained rather than deleted.

Verification and evidence

The inventory and post-remediation exports were compared against screenshots collected during the exercise.

Test	Observed result	Evidence
Directory inventory	One potential orphan flagged among three named identities.	Inventory CSV; E08
Dependency checks	No matching service or scheduled-task principal on DC01 or WS01.	E09; E10
Account remediation	Enabled=False; backup groups absent; Domain Users remains.	Post-remediation CSV; E11
Backup ACL configuration	Read & Execute on source; Modify on backup destination.	E05
Backup task permission test	Not verified; no successful user-context result captured.	Unfinished



E08. The inventory flags svc-legacy-reports as a potential orphan.

Other observations and limits

OktaService

The account belongs to Domain Users and its AD Description field is empty. PasswordNeverExpires is True. This does not, by itself, show unauthorized access or prove missing password rotation. Local rights on the Azure member server, account ownership records, and the installation-time permissions warning from Project 04 were not resolved here. No settings were changed on the account.

Backup identity

The backup groups and NTFS permissions were configured, but the attempted scheduled task test did not produce verified output. The identity was returned to a disabled state. Any temporary scheduled task or locally granted batch-logon right should be checked and cleaned up if still present. No effectiveness result is claimed.

Limits of the dependency check

The searches covered Windows service StartName and scheduled-task principals on two machines, not every application, script, stored credential, group policy or host in the environment. Zero matches cannot establish that an identity is unused across a real enterprise.

Governance outcome

In the lab, technical remediation was demonstrated for svc-legacy-reports. The business retirement decision and approval were simulated. No independent access owner certified the results, and this exercise does not establish compliance with a formal standard.

Next checks

For a fuller review: name a service-account owner, record application dependencies, establish credential rotation practices, review effective directory and local permissions, and confirm the temporary Task Scheduler configuration has been removed. Expand discovery to cloud application identities when the Entra ID lab begins.

Source records

Service-Account-Inventory.csv (three accounts, before remediation); Orphan-PostRemediation.csv (svc-legacy-reports only, after remediation). Screenshots E01-E11 and the PowerShell procedure notes are included in the project package.